MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 034 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD GUIDE · MANUFACTURING SCOPE

CMMC for Manufacturers: Where the CNC Machine Sits in Scope

CMMC for manufacturers turns on one scoping rule. A tour from the CAD station to the loading dock, classifying CNC machines, OT, and test equipment.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

CMMC · MANUFACTURING · SPECIALIZED-ASSETS · OPERATIONAL-TECHNOLOGY · SCOPING

A machine shop's CMMC boundary is usually drawn by someone sitting in the engineering office, and it usually stops at the door to the floor, as though the controlled drawing on the CAD screen stopped existing once it became a program running on a five-axis mill. It does not. CMMC for manufacturers is mostly an IT project until the drawing crosses that door, and then it becomes a question the regulation answers with unusual precision - one that most shops have never read.

The answer lives in Table 3 of 32 CFR 170.19. Level 2 sorts every asset into five categories: CUI Assets, Security Protection Assets, Contractor Risk Managed Assets, Specialized Assets, and Out-of-Scope Assets. Specialized Assets are the ones that "can process, store, or transmit CUI but are unable to be fully secured," and the rule names six kinds: IoT devices, IIoT devices, operational technology, government-furnished equipment, restricted information systems, and test equipment. At Level 2 they are in scope but not tested against the 110 requirements. The contractor must list them in the asset inventory, the SSP, and the network diagram, and show they are managed under its own risk-based policies. The assessor reviews the SSP and goes no further. Level 3 is stricter, and the summer's pause on third-party assessments changed none of this text.

That reads like an exemption for the shop floor. It is an exemption for the machines alone, and the way to see the difference is to walk the building.

FIELD COPY
ISSUE Nº 034
CMMC

6

KINDS OF SPECIALIZED ASSET NAMED IN 32 CFR 170.19 - IOT, IIOT, OPERATIONAL TECHNOLOGY, GOVERNMENT-FURNISHED EQUIPMENT, RESTRICTED INFORMATION SYSTEMS, AND TEST EQUIPMENT

0

OTHER CMMC SECURITY REQUIREMENTS A LEVEL 2 ASSESSOR TESTS A SPECIALIZED ASSET AGAINST, ONCE THE SSP HAS BEEN REVIEWED

5

SPRS POINTS RIDING ON 3.8.7, REMOVABLE MEDIA CONTROL - THE USB STICK THAT WALKS DRAWINGS TO THE FLOOR

Stop one: CMMC for manufacturers starts in the engineering office

Start at the CAM workstation, where a programmer opens a customer's drawing marked with a distribution statement and generates the toolpath. DFARS 252.204-7012 defines technical information to include process sheets and executable code, which makes a part program generated from a controlled drawing very hard to argue out of being controlled technical information. A manufacturer should assume the G-code inherits the drawing's status until someone with authority says otherwise.

That makes the CAM workstation, the file server holding the programs, and the DNC server that queues them for the floor plain CUI Assets, assessed against every Level 2 requirement. They are ordinary computers doing ordinary IT work, and the category that forgives a machine tool offers them nothing. Most of the real control effort in a manufacturing program lands in this room.

Stop two: the doorway, where CUI changes hands

Programs usually reach the floor one of two ways, and both are in scope. The first is a network: a DNC link through a switch to the controllers. Under 170.19 an asset that transmits CUI is a CUI Asset, so the switch and cabling carrying those programs sit inside the boundary. That is the practical case for giving the floor its own segment behind a firewall that denies by default. 3.13.1 (boundary protection) and 3.13.6 (deny all, permit by exception) carry 5 SPRS points each, and both are assessed on the in-scope firewall doing the separating, not on the machines behind it. The

broader boundary decision was priced here earlier; the narrower point is that a flat network from CAD to spindle makes every device on it harder to explain.

The second way is the USB stick, which is media containing CUI. 3.8.7, control the use of removable media, is worth 5 points and applies to the engineering workstation that writes the stick. 3.8.8 (3 points) bars portable storage with no identifiable owner, and 3.8.3 (5 points) requires sanitizing media before reuse or disposal. A drawer of unlabeled thumb drives next to the mills fails all three before anyone looks at a controller. Owned, logged transfer drives, or a DNC path that retires them, is the cheaper conversation.

The rule excuses the machine. It does not excuse the pipe that feeds it, the stick that walks to it, or the vendor who dials into it.

◆ THE ENDURING EXCEPTION, DEFINED

32 CFR 170.4 defines an enduring exception as a system where full compliance is not feasible, and names test equipment, OT, and IoT among its examples. No operational plan of action is required, but the circumstance must be written into the system security plan. Specialized Assets and GFE may qualify.

Stop three: the machine floor, where the category earns its name

Now the controller. Picture a horizontal mill whose control runs an operating system its vendor stopped patching long ago, with no way to add multifactor authentication and a hard drive holding a folder of part programs. This is the asset the rule was written for. It is operational technology under the definition in 170.4: a programmable system that causes a direct change in the physical world. As a Specialized Asset it is not scored against 3.14.1 flaw remediation or 3.5.3 MFA. If full compliance is not feasible, the enduring exception definition allows the circumstance to be documented in the SSP without an operational plan of action.

What the rule demands instead is a risk-based treatment an assessor can read: which network segment the machine sits on, what can reach it, how programs arrive and get purged, who may touch the USB port. The SSP entry for that mill is the control. "Legacy OT, not assessed" documents nothing.

Vendor remote access is where that entry usually falls apart. Consider a machine builder's remote-support gateway, fitted with its own cellular connection so a technician can diagnose a spindle fault from another state. The mill itself will not be scored against 3.7.5, which requires MFA for nonlocal maintenance, or 3.1.12, monitoring of remote sessions. But the gateway is a path from the outside world to a device holding controlled programs, the network diagram has to show it, and the risk-based policy the SSP must describe will look a great deal like those two controls anyway: off by default, opened per session, supervised, logged. If the path runs through your firewall instead, that firewall is a Security Protection Asset, assessed on what it provides.

Stop four: inspection, where test equipment is named outright

The coordinate measuring machine is the asset the regulation names most nearly by function. Test equipment, per 170.4, is hardware and associated IT components used to test products and contract deliverables, so the CMM and the PC running its measurement software both fit. That matters because inspection software can import the 3D model to measure against, which puts controlled technical data on a machine whose update schedule the shop may not control.

The Specialized Asset category covers the CMM. It does not cover where the results go. An inspection report that carries characteristics from a controlled drawing is uploaded to a quality system, emailed to a customer, or printed for a traveler, and each of those destinations is a CUI Asset in its own right. Reports scattering into tools no one diagrammed is the CUI sprawl problem in a shop setting.

Stop five: shipping, and what Level 3 takes back

The loading dock is mostly out of scope, and a shop should be able to show why. If the label printer and the barcode scanners cannot process CUI and do not protect anything that does, they are Out-of-Scope Assets, and the rule asks only that the contractor be prepared to justify that. The real exposures are paper and property. A traveler with a controlled drawing stapled to it must not ride out in the box, and 3.8.5, accountability for CUI media in transport, applies to any drawing that legitimately leaves. Government-furnished equipment, such as a government-owned test set staged for return, is a Specialized Asset by name and belongs on the inventory before it goes back.

This is where the Level 2 bargain ends. Table 5 of the same section keeps Specialized Assets in the Level 3 scope but changes the assessment to a limited check against Level 2 and a full assessment against every Level 3 requirement, with intermediary devices permitted to meet requirements the asset cannot meet itself. The unpatchable mill a Level 2 shop documents, a Level 3 shop has to wrap in something that can be tested, so a manufacturer eyeing Level 3 work should price the controllers first. The Level 2 baseline underneath is laid out on our CMMC Level 2 page, and the enclave architecture page covers the boundary the floor segment hangs from.

Finish the tour with a clipboard instead of a camera. Every stop produces lines in three documents: the inventory, the SSP, and the network diagram. If a line is missing when an assessor walks the same route, the category cannot help, and the machine is just an unexplained computer with a spindle attached. A readiness

scan is a quick first check on whether the paperwork matches the building. ◆

MORE ISSUES

mactechsolutionsllc.com/maczine

new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF

mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.

Published from Git, reviewed like code.